SECURITY



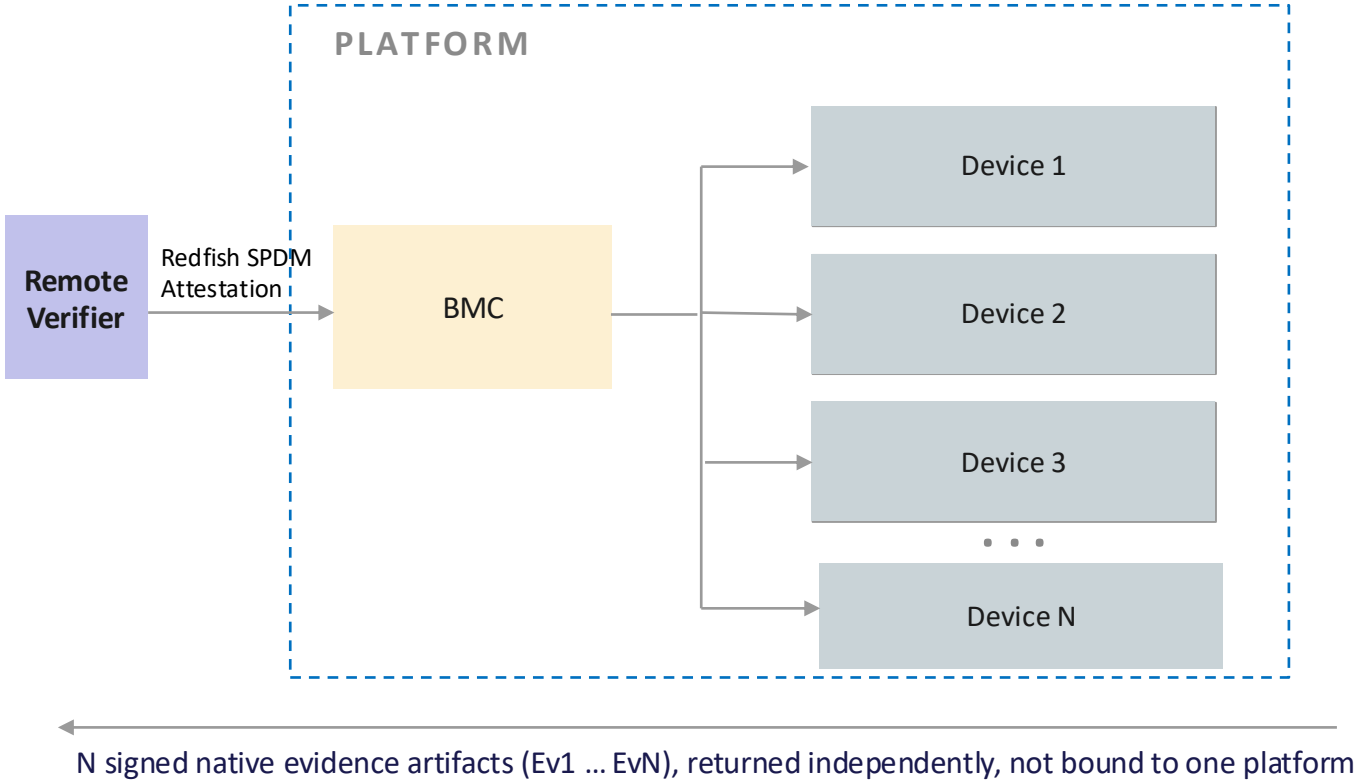
# BMC-Mediated Platform Composite Attestation via Redfish


Xiling Sun *Principal Firmware Engineer, Microsoft*

Roksana Golizadeh Mojarad *Principal Software Engineer, Microsoft*




# Platform Attestation today is Disaggregated




- **No aggregate**: the verifier must discover, identify and attest each device separately; N Redfish round trips, each bound to its own verifier nonce.
- **No common envelope**: SPDM measurements, device EATs and Concise Evidence come back as independent artifacts, with no platform-level binding.
- **Collector unbound:** attesting the BMC RoT requires its own SPDM responder path, and that result is not bound to the device evidence the BMC relays.

**Missing today:** no platform trust anchor signs one attestation that binds this platform's BMC measurements to its devices' evidence.

# Why We Need a Platform Claim

## Platform composite model

✓ One Redfish request returns one platform-scoped, signed artifact

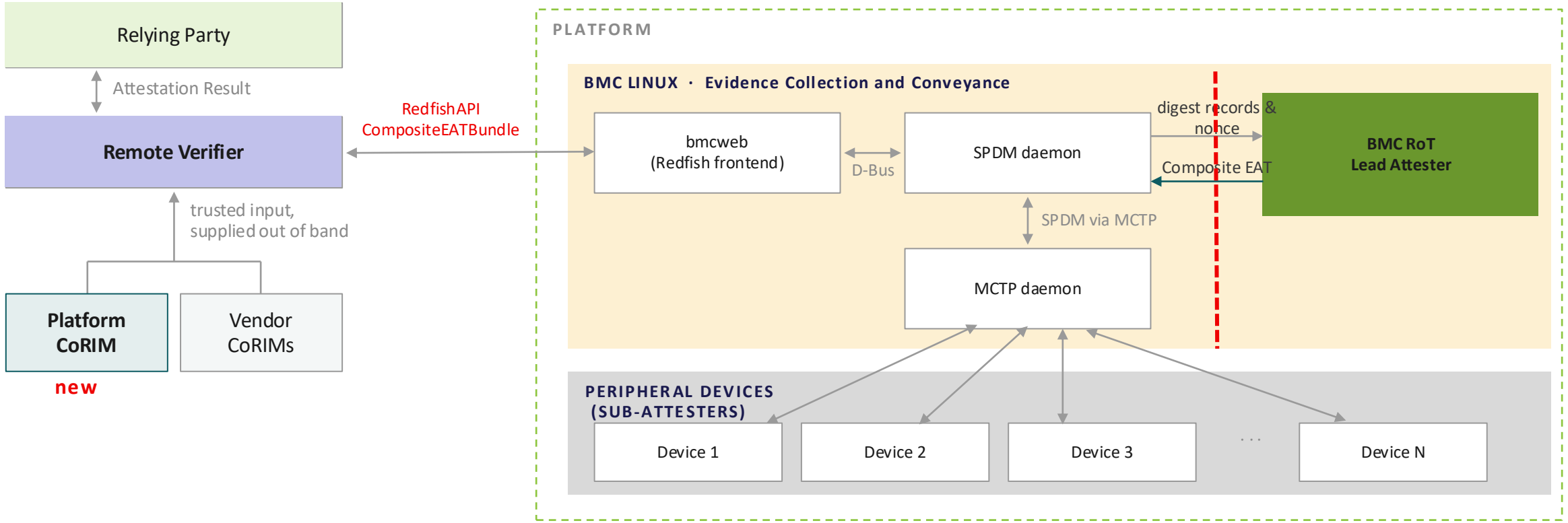
✓ Signed digests commit to exactly which evidence is included

✓ Native evidence is preserved and carried in one bundle

✓ Lead attester adds its own measurements and signs the token

**Outcome**: One fresh attestation, signed by the platform RoT, appraised against expected platform composition.

# Platform Composite Attestation Architecture




**RFC 9334 ROLES**

IETF Remote ATtestation procedureS (RATS) Architecture

- Platform = Composite Device
- BMC RoT = Lead Attester
- Devices = Sub-Attesters within the Composite

**TRUSTED INPUTS**

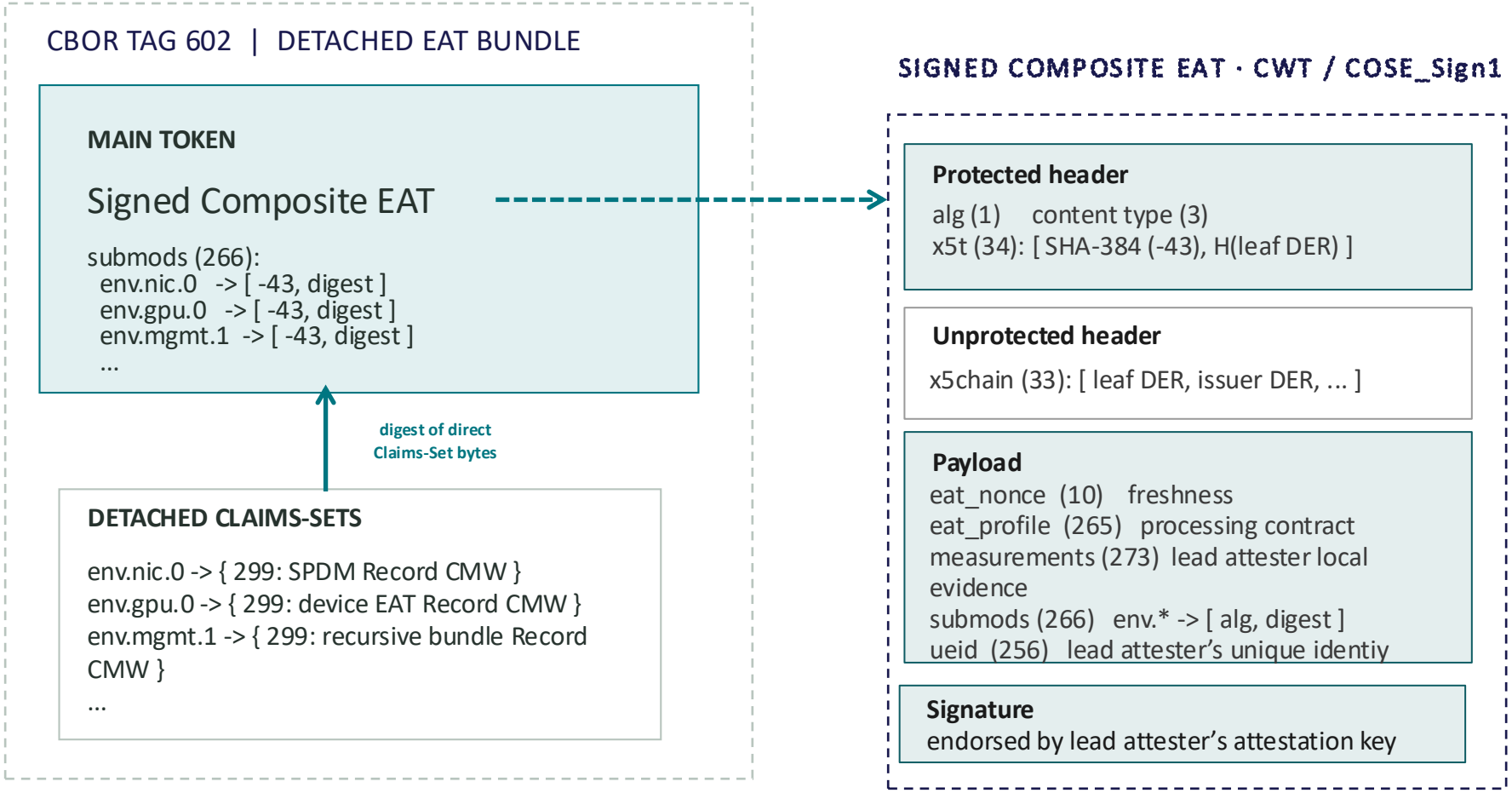
- Vendor CoRIM (existing practice)per-device reference values and endorsements. CoRIM = Concise Reference Integrity Manifest
- **Platform CoRIM:** expected composition: authorized Lead Attester, expected env.* environments and cardinality, platform reference values

# Composite EAT: What Is Present

| | |
|---|---|
| • Verifier nonce | one freshness value for the entire platform observation |
| • Lead Attester identity and profile | which platform RoT made the observation, and how to interpret it |
| • Lead Attester's measurements | platform RoT's own state, bound with the device evidence it relays |
| • Device evidence digests | commitments to detached native device evidence |

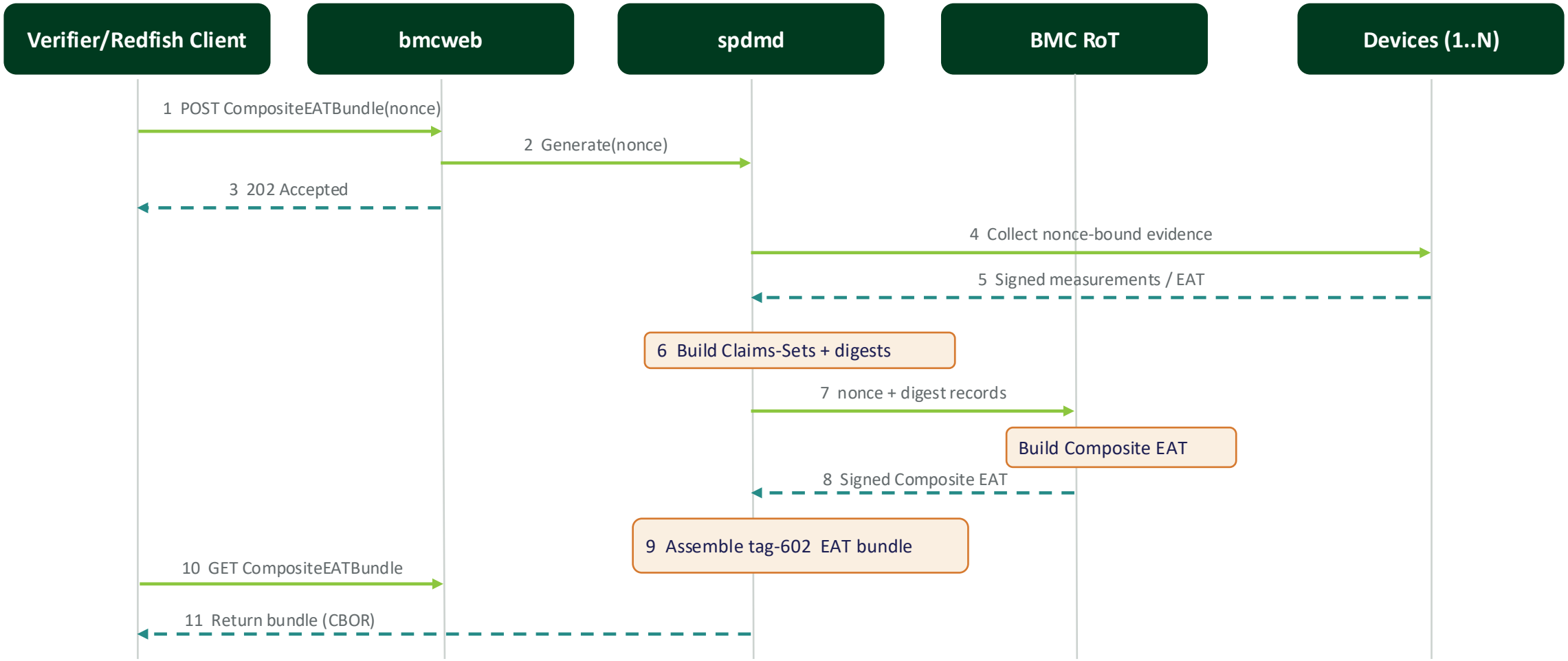
**BMC RoT constructs and signs the Composite EAT; each peripheral signs its own native evidence.**

# Composite EAT Bundle Anatomy

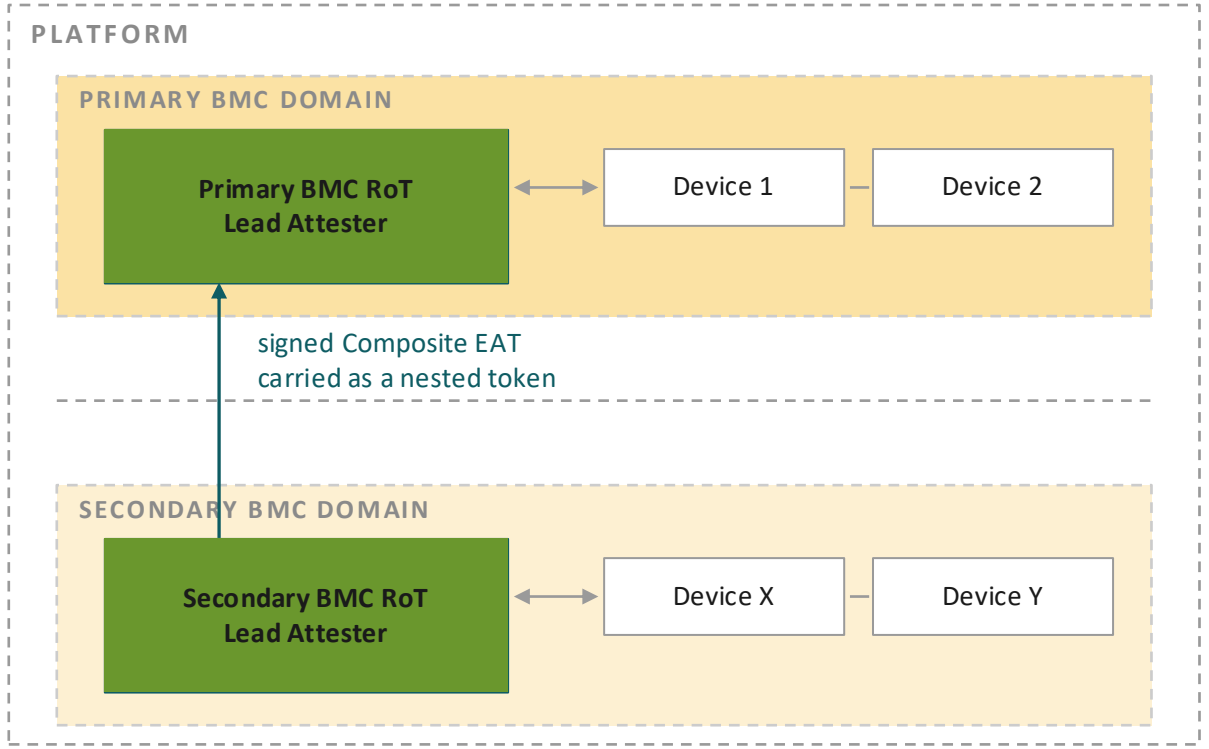



- Same env.* label binds digest to Claims-Set
- Digest input is deterministic CBOR(Claims-Set), not the bundle bstr wrapper
- Native Evidence bytes remain independently validated and are not re-encoded

# End-to-End Platform Attestation Flow



# Nested Composite Devices: When Nesting Applies




**Composite EAT · primary Lead Attester**

eat_nonce (10)
ueid (256) primary RoT
submods (266):
env.nic.0 -> [ SHA-384, digest ]
env.mgmt.1 -> nested token

**Composite EAT · secondary Lead Attester**

eat_nonce (10) its own nonce
ueid (256) secondary RoT
submods (266):
env.gpu.0 -> [ SHA-384, digest ]
env.gpu.1 -> [ SHA-384, digest ]

*Submodules inherit nothing from the containing token — the nested token carries its own claims.*

**WHEN THIS APPLIES**

- Secondary bridges MCTP — the primary reaches the devices itself; they are ordinary Sub-Attesters and the bundle stays flat, with no nesting
- Secondary has its own RoT and attestation key — it is a Lead Attester, and its signed token nests as shown above
- Secondary terminates SPDM but has no signing identity — it is a relay: device evidence must stay signed end-to-end and the primary commits digests over it

**SPEC BASIS**

- RFC 9334: a Composite Device may contain Attesters that cannot communicate with the Verifier directly; the multi-chassis router is the same shape
- RFC 9711: a submodule may be a nested token, which can be any EAT including a Detached EAT Bundle; carry it inline or commit it by digest as a detached Claims-Set.

- The primary must never sign a digest over evidence the secondary handed it unsigned — that launders unverified evidence into a platform-signed artifact.

# Platform CoRIM: What Should Be Present

**Observed: Composite EAT Bundle**

- Lead Attester UEID and certificate chain
- RoT and BMC measurements
- Signed submods environment set
- Native device identities and measurements

**Expected: Platform CoRIM**

→ Authorized Lead Attester key or CA

→ Platform reference values

→ Expected target environments

→ Identity constraints and vendor CoRIM locators

Vendor CoRIMs supply device reference values; verifier policy decides whether the platform is acceptable.

# Verifier: Appraise the Platform

1. **Cryptographic validation**

   Validate the bundle, certificate chains, signatures, nonce, and detached digests.

2. **Composition appraisal**

   Compare the signed submods with expected Platform CoRIM environments.

3. **Identity and firmware appraisal**

   Appraise native device evidence against identity policy and vendor CoRIM reference values.

Result: completeness and anti-substitution become checkable appraisal outcomes.

# Building on Existing Standards

| Layer | Existing building blocks | Proposed contribution |
|---|---|---|
| Platform conveyance | Redfish SPDM Attestation API | Redfish API extension for Composite EAT Bundle Collection |
| Platform evidence | EAT and RFC 9711 Detached EAT Bundle | OCP Platform Composite EAT profile |
| Platform endorsement | CoRIM / CoMID | Platform CoRIM profile |
| Verifier Service | Project Veraison | Veraison Attestation Verification Service for Platform Composite EAT including modification to composite EAT library |

# Reference Implementation and Standardization

**Available now**

- Azure GitHub: Composite EAT SDK for BMC integration
- Early adoption in Aspeed/Nuvoton OpenBMC SDK
- End-to-end platform attestation with verifier appraisal

**Standardization**

- Submit Platform Composite EAT Profile to OCP & IETF RATS
- Submit Platform Composite EAT API to DMTF Redfish
- Align platform CoRIM profile and cross-vendor interoperability

The implementation demonstrates feasibility; the specifications define interoperability.

# Call to Action

- **IETF RATS —** review and progress the Platform Composite EAT profile draft to RFC
- **DMTF Redfish —** review and standardize the platform composite-attestation interface
- **Device vendors —** validate native SPDM, EAT, and Concise Evidence interoperability
- **Platform operators —** review Platform CoRIM against real inventory and firmware policy
- **OCP community —** provide deployment feedback and align the standards work

Today the reference implementation demonstrates feasibility.
**Next**: standards convergence and cross-vendor interoperability.

# Thank You!

